Final Digital Forensic Investigation Report

Case DF-2026-1102-017 | Host ci-worker-03 | All times UTC | Incident date 2026-10-29

01 | Executive Summary

On 2026-10-29, ci-worker-03, an Ubuntu 24.04 CI/CD worker, exhibited sustained CPU utilization above 95% by a Python process running as worker. Authentication telemetry recorded key-based SSH access from 192.168.4.35 at 08:41:19 UTC. Subsequent records support configuration discovery, staging of runner configuration, an outbound upload attempt, installation of a user-level systemd service, and command-history suppression.

Assessment: unauthorized interactive use of the worker account is strongly supported by the correlation of authentication, process, file-system and command records. Successful transfer of the staged archive is not established because HTTP response and packet payload were not preserved. Root-level compromise is not established.

02 | Background, Scope and Objectives

ci-worker-03 executes CI build jobs under a dedicated worker account (UID 1002). The host uses OpenSSH, systemd, and a service named ci-agent.service. Scope is the host activity from 08:30 to 10:15 UTC on 2026-10-29; analysis is limited to eight reconstructed logical evidence groups.

Objectives: establish access vector, reconstruct the command sequence, identify persistence and data-access implications, evaluate privilege escalation, and distinguish observed events from unresolved possibilities. No external systems or credential stores were examined.

03 | Evidence Acquisition and Preservation

At 09:14 UTC an incident record was opened, network isolation was authorized and applied at 09:22 UTC. Logical exports began at 09:36 and ended at 10:08 UTC. Reference inventory identifiers AUTH-01, HIST-01, FS-01, PROC-01, NET-01, SUDO-01, IR-01 and COC-01 organize the case.

The modeled procedure preserves raw log copies before interpretation, records source path, UTC acquisition time, operator, storage destination and SHA-256. Logical exports cannot independently establish the absence of tampering before collection; no disk image, RAM image or external provider records are available.

04 | Methodology and Analytical Limits

Normalize source clocks to UTC, correlate SSH/PAM sessions with command observations, examine account and sudo policy, review user service units, align CPU and network telemetry, and test alternative explanations. The timeline retains raw events separately from analyst conclusions.

Evidence grades: direct record (logged event), correlated inference (multiple records support interpretation), and unverified possibility (missing corroboration). Command history is reconstructed from mixed history and monitoring records; it is not assumed to be a complete shell transcript.

05 | Authentication and SSH Analysis

At 08:41:02 UTC sshd recorded a failed password for worker from 192.168.4.35:51108. At 08:41:19 UTC the same source successfully authenticated by ED25519 public key using source port 51114; PAM then opened a session for UID 1002. This pattern is consistent with an operator switching authentication methods, but does not prove who controlled the key.

No accepted root SSH login appears in the scoped records. The source is RFC1918 internal addressing; it must not be described as an Internet-routable attacker host. Investigators should compare the presented key fingerprint with authorized_keys and key-management records.

06 | Account and Permission Review

worker is a non-root service account with UID 1002. The observed session used the account directly, not a newly created identity. Review of the available account snapshot found no supported creation of a new local user or membership change.

The account had permission to run a limited systemctl status command through sudo. That capability does not itself establish arbitrary root execution. User-level systemd persistence does not require root access.

07 | Command and Python Activity

At 08:42:03 UTC the session ran whoami, id, hostname and uname -a. At 08:43:12 UTC python3 -q started an interactive interpreter; at 08:43:48 UTC a Python one-liner reported its process ID. At 08:44:30 UTC find enumerated environment files under /opt/ci.

The Python REPL is not inherently malicious. In this case, its timing within a suspicious SSH session, later creation of a hidden Python service script, and CPU anomaly elevate its significance. The precise REPL statements are not recoverable from the scoped artifacts.

08 | File-System and Configuration Access

At 08:45:07 UTC the operator read /opt/ci/config/runner.env; at 08:46:21 UTC a copy was staged as /tmp/.ci_env.cache. At 08:47:14 UTC tar packaged that copy with build-metadata.json into /tmp/.runner-support.tgz.

At 08:54:22 UTC the temporary cache and archive were deleted. The modeled file-system record supports creation and deletion events but does not recover the full contents of the deleted archive. The original runner.env is treated as sensitive CI configuration, not assumed to contain particular secrets without content review.

09 | Process and CPU Analysis

At 08:53:10 UTC the user service started python3 /home/worker/.local/share/.ci_health.py. At 09:03:17 UTC the monitoring agent reported PID 18422 at 96.4% CPU. The process ran as worker and was associated with the user service cgroup.

High CPU is an indicator of unusual execution, not proof of cryptocurrency mining. No mining pool protocol, wallet address, or confirmed miner binary was observed. Alternative explanations include a buggy health script or a computational payload.

10 | Network Analysis

At 08:48:09 UTC a curl command attempted an HTTPS POST to https://198.51.100.24/upload with the staged archive as its body. 198.51.100.24 is a documentation-range address used as an analytical stand-in; the case does not identify an actual remote service.

Network telemetry corroborates an attempted outbound connection but lacks a captured HTTP response or payload. Therefore, archive delivery and data exfiltration success remain unconfirmed. Destination reputation and actual bytes transmitted cannot be assessed.

11 | Privilege Escalation Review

At 08:49:33 UTC the operator issued sudo -l; at 08:50:02 UTC sudo recorded execution of /usr/bin/systemctl status ci-agent.service under the configured policy. The status subcommand was authorized and no elevated shell was observed.

Conclusion: privilege enumeration and limited sudo execution occurred; a successful privilege escalation to root is not supported. Follow-up should inspect sudoers for unsafe wildcard commands and check for alternate privileged execution telemetry.

12 | Persistence Analysis

At 08:51:18 UTC ~/.config/systemd/user was created; at 08:52:04 UTC ci-health.service was written. The unit set ExecStart=/usr/bin/python3 /home/worker/.local/share/.ci_health.py and Restart=always. At 08:52:49 UTC systemctl --user enable --now started it.

This constitutes user-context persistence through a systemd user service. It does not imply system-wide root persistence. A reboot-survival claim requires verifying linger settings and user-session behavior; neither is established by the scoped records.

13 | Anti-Forensics and Concealment

At 08:54:22 UTC rm -f deleted temporary staging artifacts. At 08:55:03 UTC history -c and unset HISTFILE were invoked. These commands are consistent with efforts to reduce local traceability but cannot erase centralized auth logs, process monitoring or previously collected audit records.

The lack of some shell-history lines is not independent proof of deliberate deletion. The observed command pair is the stronger basis for assessing an attempted history suppression technique.

14 | Chronology and Attack Reconstruction

The 24-event chronology in 04_Forensic_Timeline.xlsx begins with the failed SSH attempt at 08:41:02 UTC and ends with logical export completion at 10:08:00 UTC. Key phases: access 08:41; discovery 08:42–08:45; staging 08:46–08:47; outbound attempt 08:48; privilege review 08:49–08:50; persistence 08:51–08:53; concealment 08:54–08:55; detection and containment 09:03–09:22.

This sequence is an analytical reconstruction rather than an assertion that every command was captured. Event source IDs permit row-level cross-reference to the inventory, notes, and custody records.

15 | Competing Hypotheses and Testing

H1 — Unauthorized key use: supported by atypical interactive SSH access, secret-file staging, attempted upload and persistence. Remaining uncertainty: identity of key operator and original key exposure path.

H2 — Authorized CI maintenance: weakened by hidden temporary archives, outbound upload to an unapproved destination, history suppression and unexplained user service. Requires a change ticket or operator approval record to rehabilitate.

H3 — Automated CI workload malfunction: could explain CPU consumption, but does not adequately explain the interactive SSH session, manual sudo enumeration and shell-history commands. A mixed scenario (legitimate login followed by misuse) remains possible.

16 | Indicators, ATT&CK and Findings

Principal indicators: internal SSH source 192.168.4.35; the worker login; /tmp/.runner-support.tgz; /tmp/.ci_env.cache; ~/.config/systemd/user/ci-health.service; hidden .ci_health.py; curl POST syntax; and history suppression commands. Hash values in the inventory identify modeled evidence records, not verified malware signatures.

Applicable ATT&CK techniques include T1078 (Valid Accounts), T1059.006 (Python), T1083 (File and Directory Discovery), T1005 (Data from Local System), T1560.001 (Archive via Utility), T1048.002 (Exfiltration Over Asymmetric Encrypted Non-C2 Protocol, attempted), T1543.002 (Systemd Service), and T1070.003 (Clear Command History). Mapping details and limitations are in 06_MITRE_ATTACK_Mapping.pdf.

17 | Conclusions, Recommendations and References

Confidence is high that the worker account was used interactively to access CI configuration and establish user-context persistence; moderate that an outbound archive transfer was attempted; low that the transfer succeeded; insufficient evidence for root compromise or cryptomining.

Priority actions: revoke and rotate the worker SSH key; inspect CI secret exposure and rotate affected tokens as indicated; disable and preserve the suspicious user unit; rebuild the worker from a trusted image; enforce SSH source allowlisting, least privilege and egress restrictions; collect centralized audit, proxy and EDR records; implement immutable log forwarding and service-unit monitoring.

References: MITRE ATT&CK Enterprise techniques T1078, T1059.006, T1083, T1005, T1560.001, T1048.002, T1543.002 and T1070.003 (attack.mitre.org); OpenSSH sshd(8); systemd.unit(5), systemd.service(5); NIST SP 800-86 Guide to Integrating Forensic Techniques into Incident Response. Appendix references: event workbook, inventory, IOC list, custody ledger and terminal exhibits.